

安裝精靈 / Day 0/1 卡關修補法律與合規警告 (v3.37)

本檔性質：安裝精靈、預設密碼、自動下載與主動推播之合規提醒，不構成法律意見。累積適用於 v3.25.10 → v3.37 全部 §6 聲明。

English version: [SETUP_WIZARD_LEGAL_NOTICE_EN.md](#)

⚠️ 重要：v3.37 修補了「電腦小白卡關」14 條硬傷

v3.37 涉及：

- 公司主檔寫入 (PDF 對外文件之公司名 / 統編 / 地址 / 電話)
- 密碼修改 (變更系統存取控制之關鍵)
- 預設帳號 admin/admin123 (必須立即更換)
- 自動下載 PDF / Excel (瀏覽器自動觸發檔案下載)
- 主動推播 (應收逾期 / 低庫存 / 待簽核之提醒)

這些功能錯誤使用可能引發：

- ● 對外 PDF 印錯公司名 (契約爭議)
- ● 預設密碼未換 → 資安事件 (個資 / 營業秘密外洩)
- ● 自動下載觸發瀏覽器安全警示 (小白以為被攻擊)
- ● 主動推播誤判 → 老闆做錯決策

請務必依本檔指引使用，並於上線前完成 §7 checklist。

1. 公司主檔 (set_company_info_with_confirm)

1.1 寫入即生效於 PDF

- 設定後立即用於所有後續 PDF (報價單 / 採購單 / 銷售單 / 出貨單)
- 不溯及既往：已產生的 PDF 不會回填新公司名

1.2 統一編號

- 系統做基本格式檢查 (8 碼數字) 但不驗證統編真實性
- 客戶須自行確認統編正確 → 否則對外 PDF 之 B2B 發票買方無法扣抵

1.3 公司名 / 地址之法律效力

- PDF 上之公司名應為經濟部商業司之登記名稱
- 若使用簡稱 / 別名而非登記全名，第三方可能於契約爭議時主張不認該 PDF
- 改名應由有權人員 (董事 / 總經理) 授權

2. 預設密碼 (admin/admin123)

2.1 強制更換義務

- 安裝後第一次登入即顯示警告 toast：「您正使用預設密碼」
- Login 頁亦顯示提示：「⚠️ 登入後請立即改密碼」
- install.bat / install.sh 結尾亦顯示「請立即更換預設密碼」

2.2 仍未更換之風險

未更換預設密碼於業界視為基本資安疏失，可能：

- ● 遭內部員工 / 訪客 / 工讀生未授權進入系統
- ● 違反《個人資料保護法施行細則》第 12 條「資料安全維護措施」
- ● 違反 ISO/IEC 27001、CMMI 等資安標準要求
- ● 客戶 / 供應商於資安稽核時可能拒絕繼續往來

2.3 密碼強度要求

v3.37 強制：

- 長度 ≥ 8 字元
- 至少 1 個英文字母 + 1 個數字
- 不得為常見密碼 (admin123 / password / 12345678)

更嚴格要求 (建議)： ≥ 12 字元 + 大小寫混合 + 特殊符號。

3. 自動下載 PDF / Excel (v3.37 D1-2/D1-3)

3.1 行為說明

LLM 對話中講「印 SO-001」「匯出客戶清單」時，Chat 元件偵測到工具回傳之 pdf_base64 / base64 即自動觸發瀏覽器下載。

3.2 瀏覽器安全行為

- 部分瀏覽器 (Chrome / Edge) 會於連續自動下載時詢問是否允許

- 客戶須引導使用者**允許 erpilot 來源**之自動下載
- 若使用者拒絕，需手動點對話訊息中之 [點此下載 PDF] 連結

3.3 檔案處置

- 下載之 PDF / Excel 含**個資 + 商業機密** (依各文件而定)
- 客戶應依 v3.36 §2 規範控管下載後之檔案

4. 主動推播 (proactive_alerts)

4.1 推播邏輯 (v3.37 預設)

- 應收逾期：SO `payment_status=unpaid` 且 `order_date` > 30 天前且 `status in (delivered/confirmed/shipped)`
- 低於安全庫存：Inventory `qty_on_hand` < Part `safety_stock`
- 待籤核：ApprovalRequestV2 `status=pending`

4.2 限制

- 推播為**啟發式提醒**，不取代正式催收 / 採購 / 籤核流程
- 老闆**不應**僅憑推播結果直接致電客戶催款 → 應先請會計覆核帳齡分析
- 推播不處理：跨年帳齡 / 部分付款 / 已協議延期之客戶

4.3 假陽性風險

- 若 SO 之 `payment_status` 未即時更新 (例如客戶已付款但系統未錄) → 會誤推播
- 客戶應定期對帳確保 `payment_status` 正確

5. 自動下載與資安 (瀏覽器層)

5.1 觀念

- 自動下載**不**等同於「使用者授權下載」
- 客戶之 IT 政策 (如禁止下載財報 PDF 到本機) 若與此衝突，應**關閉**自動下載

5.2 關閉方法

如需停用自動下載：

- 前端：移除 Chat.tsx 中 `triggerAutoDownload(data.tool_calls)` 呼叫
- 後端：將 LLM tool 回傳之 `pdf_base64` / `base64` 改為 `null` (保留 `download_url` 由 user 主動點)

6. 免責條款 (累積適用 v3.25.10 → v3.37)

於適用法律所允許之最大範圍內：

1. 安裝精靈 erpilot 之 OnboardingWizard 為功能引導，不承擔客戶於精靈後填入錯誤資料、或未完成精靈而導致之業務損失。
2. 預設密碼 erpilot 已提示客戶更換預設密碼；客戶未更換所衍生之任何資安事件、資料外洩、契約爭議，erpilot 不承擔責任。
3. 公司主檔 erpilot 不驗證統編 / 公司名 / 地址之法律真實性；客戶須自行確認與經濟部登記資料一致。
4. 自動下載 erpilot 之自動下載為便利性功能；客戶須依其 IT 政策評估是否啟用；下載後之檔案處置責任由客戶自負。
5. 主動推播 erpilot 之 `proactive_alerts` 為啟發式提醒，不取代正式 ar/ap aging、安全庫存補貨、ECO/ECN 流程；客戶不應僅憑推播作重大商業決策。

7. 客戶導入前 Checklist (v3.37 補強)

導入 erpilot v3.37 前，請確認：

7.1 D0 安裝完成

- ☐ 已執行 `install.bat` / `install.sh` 並見到「安裝完成」訊息
- ☐ 瀏覽器自動開啟 `http://localhost:5173`
- ☐ Docker 鏡像已含 `fonts-noto-cjk` (試印一份報價單 PDF 確認中文不亂碼)

7.2 D0 第一次登入

- ☐ 用 `admin/admin123` 登入成功 + 看到 toast 警告
- ☐ 立即在 Chat 講「改密碼 我的新密碼是 `MyN3wP@ssw0rd!`」
- ☐ 登出 + 用新密碼重登成功

7.3 D0 設定公司

- ☐ 在 Chat 講「公司叫 [貴司全名] 統編 [8 碼]」
- ☐ 試印一份 SO PDF → 確認頂部公司名是新設定的 (不是「erpilot 範例公司」)

7.4 D1 第一次對話

- ☐ Chat 開啟即見「您好！我是 erpilot AI 助手」歡迎訊息
- ☐ 點任一範例問題 → AI 有回應
- ☐ 講「印 SO-XXX」→ 瀏覽器自動下載 PDF (或詢問允許)

7.5 D2-7 業務操作

- ☐ 講「新增客戶 [公司名]」→ 確認 ConfirmCard 出現 + 自動編號 CUS-####
- ☐ 講「列出角色」→ 看到中文角色名 (非天書)
- ☐ 講「我要匯入 Excel 客戶清單」→ 顯示 3 步流程
- ☐ 講「今天有什麼要注意的？」→ 顯示主動推播

7.6 上線前合規

- ☐ 已完成 v3.25.10 → v3.36 之全部 checklist (PDPA / 營業秘密 / 字型授權)
- ☐ 已正式更換預設密碼 (員工亦同)
- ☐ 已訂定對外 PDF 之簽核流程
- ☐ 已對員工進行 erpilot 1 小時導覽訓練

版本 : v3.37 (2026-05-21) 作者 : erpilot 法務團隊 (內部) 對應程式 :

- `backend/app/agents/domains/setup_wizard_tools.py`
- `backend/app/services/print_service.py` (公司主檔整合)
- `backend/app/agents/domains/hard_write_tools.py` (客戶自動編號)
- `backend/app/agents/domains/print_export_tools.py` (空品項警示)
- `backend/Dockerfile` (中文字型)
- `frontend-desktop/src/pages/{Login,Chat,Dashboard}.tsx`
- `install.bat` 、 `install.sh`